

README — Kit de Encuesta COSO-Ciber v2025.1

Diagnóstico de Indicadores y Métricas de Ciberseguridad en el Marco COSO

Aplicación a España • Contexto ENS / NIS2 / DORA • Perspectiva Comparada Internacional

KIT DE DIAGNÓSTICO COSO-CIBER • v2025.1 • ABRIL 2026
Encuesta integral de métricas de ciberseguridad – Marco COSO

¿Qué es este Kit?

El **Kit COSO-Ciber** es un instrumento de diagnóstico organizacional diseñado para evaluar, de forma sistemática y reproducible, el nivel de adopción de indicadores y métricas de ciberseguridad alineados con el marco **COSO** (Committee of Sponsoring Organizations of the Treadway Commission), en sus tres dimensiones complementarias:

- COSO ERM 2017 (Enterprise Risk Management — 20 Principios)
- COSO IC 2013 (Internal Control — Integrated Framework)
- COSO CGF 2026 (Corporate Governance Framework — Principio 8: Supervisión del ciberriesgo)

El kit ha sido desarrollado en el contexto del nuevo paisaje regulatorio europeo (NIS2 en vigor, DORA desde enero 2025, ENS RD 311/2022) y de las tendencias de ciberriesgo emergentes 2025-2026, incluyendo la automatización adversarial por IA y la transición hacia la criptografía post-cuántica.

Inventario del Kit (7 documentos)

#	Archivo	Descripción	Audiencia Principal
a	a_encuesta_integral_coso.md	Modelo de encuesta completo (59 preguntas, 10 bloques)	Encuestados / Plataforma de encuesta
b	b_guia_metodologica.md	Diseño muestral, escalas, IGM, análisis estadístico	Investigadores / Metodólogos
c	c_narrativa_explicativa.md	Contexto, fundamentos y lógica del instrumento	Stakeholders / Comités directivos
d	d_mapero_normativo.md	Trazabilidad pregunta – marco regulatorio	Compliance / Auditores / Reguladores
e	e_plantilla_excel_igm_roi.md	Especificación de la plantilla Excel IGM + ROSI	CISOs / CFOs / Analistas GRC
f	f_plantilla_ppt_reporte_ejecutivo.md	Estructura del reporte ejecutivo para el Consejo	CISOs / Consultores / Asesores
g	g_readme_kit_encuesta.md	Este documento — guía de uso del kit	Todos

Instalación y Puesta en Marcha

Prerrequisitos

Para distribuir la encuesta:

- LimeSurvey (recomendado, autoalojado) o Google Forms
- Acceso a los canales de distribución relevantes (ver Guía Metodológica, §3.4)
- Aprobación de protección de datos por parte del DPO

Para el análisis:

- Microsoft Excel 365 o Google Sheets (para la plantilla IGM/ROI)
- SPSS / R / Python (para análisis estadístico avanzado, opcional)
- Software de análisis cualitativo: NVivo o Atlas.ti (para Bloque X, opcional)

Para el reporte ejecutivo:

- PowerPoint / Keynote / Google Slides (para implementar la plantilla del Documento f)

Pasos de Implementación

PASO 1: PREPARACIÓN (Semanas 1-4)

- Leer el Documento (c) para comprender el marco conceptual
- Revisar el Documento (b) para el diseño muestral
- Validar el instrumento con panel de expertos (mínimo 7)
- Configurar la plataforma de distribución

PASO 2: PILOTO (Semanas 5-7)

- Distribución a 30 organizaciones piloto
- Recopilar retroalimentación sobre comprensión y tiempo de respuesta
- Ajustar la encuesta según los hallazgos del piloto

PASO 3: DISTRIBUCIÓN MASIVA (Semanas 8-15)

- Lanzamiento a la muestra objetivo ($n \geq 384$)
- Seguimiento semanal de la tasa de respuesta
- Dos recordatorios: semana 3 y semana 5 de la distribución

PASO 4: ANÁLISIS (Semanas 16-18)

- Depuración y limpieza de datos
- Importar datos a la Plantilla Excel (Documento e)
- Calcular el IGM para cada organización
- Ejecutar análisis estadísticos (ver Documento b, §6)

PASO 5: REPORTE (Semanas 19-21)

- Generar informe de resultados con la plantilla PowerPoint (Documento f)
- Preparar benchmarking sectorial
- Distribución de resultados a participantes (reciprocidad)

Estructura de la Encuesta

ENCUESTA COSO-CIBER (59 preguntas)

- BLOQUE 0: Perfil Organizacional (7 preguntas) — Variables de control
- BLOQUE I: Gobernanza y Cultura (8 preguntas) — COSO ERM Componente I
 - └ 5 preguntas IAT ⚡
- BLOQUE II: Estrategia y Apetito de Riesgo (6) — COSO ERM Componente II
 - └ 2 preguntas IAT ⚡
- BLOQUE III: Desempeño – Métricas Operativas (11) – COSO ERM Componente III
 - └ 7 preguntas IAT ⚡ (mayor densidad de IATs)
- BLOQUE IV: Riesgos Emergentes 2025-26 (4) — COSO ERM P-6 + P-15
 - └ 2 preguntas IAT ⚡
- BLOQUE V: Marco Regulatorio (4) — IC Control Cumplimiento
- BLOQUE VI: Revisión, Mejora y Monitoreo (5) — COSO ERM Componente IV
- BLOQUE VII: Información y Reporte al Consejo (4) — COSO ERM Componente V
 - └ 2 preguntas IAT ⚡ (incluyendo calidad del reporte)
- BLOQUE VIII: ROI y Madurez Estratégica (3) — ERM + FAIR
 - └ 1 pregunta IAT ⚡
- BLOQUE IX: Perspectiva Comparada Internacional (3) – Benchmarking
- BLOQUE X: Reflexión Final y Aportaciones Abiertas (4) – Cualitativo

El Índice Global de Madurez (IGM)

$$\text{IGM} = (\text{C-I_GOB} \times 0,25) + (\text{C-II_EST} \times 0,20) + (\text{C-III_DES} \times 0,30) + (\text{C-IV_REV} \times 0,10) + (\text{C-V_INF} \times 0,15)$$

Escala: 1.0 (mínimo) → 5.0 (máximo)

- | | |
|-----------------------|---|
| ● 1.0-1.9 CRÍTICO | → Intervención inmediata requerida |
| ● 2.0-2.9 EMERGENTE | → Plan de mejora estructurado a 12 meses |
| ● 3.0-3.9 ESTABLECIDO | → Optimización de métricas e integración ERM |
| ● 4.0-4.5 AVANZADO | → Cuantificación financiera del riesgo (FAIR/CRQ) |
| ■ 4.6-5.0 LÍDER | → Referente sectorial; contribución a marcos del sector |

Indicadores de Alerta Temprana (14 IATs ⚡)

Los IATs son preguntas donde una puntuación ≤ 2 requiere atención prioritaria:

IAT	Pregunta	Área COSO
⚡ P-1.1	Supervisión del ciberriesgo por el Consejo	Gobernanza
⚡ P-1.2	Competencia ciber del Consejo	Gobernanza
⚡ P-1.4	Línea de reporte del CISO	Gobernanza
⚡ P-1.6	Cultura organizacional de ciberseguridad	Gobernanza
⚡ P-2.1	Integración del ciberriesgo en la estrategia	Estrategia
⚡ P-2.3	Expresión del apetito de ciberriesgo	Estrategia
⚡ P-3.1	Registro y gestión del inventario de riesgos	Desempeño
⚡ P-3.2	Madurez en gestión de vulnerabilidades	Desempeño
⚡ P-3.3	Time-to-Patch (TTP) para vulnerabilidades críticas	Desempeño
⚡ P-3.4	Time-to-Exploit (TtE) como KRI	Desempeño
⚡ P-3.5	MTTD y MTTR	Desempeño
⚡ P-3.6	Gestión de IAM/PAM y cobertura MFA	Desempeño
⚡ P-3.9	Resiliencia y continuidad de negocio	Desempeño
⚡ P-7.1	Calidad del reporte de ciberriesgo al Consejo	Reporte

Marco Normativo de Referencia

El kit cubre los principales marcos regulatorios y estándares vigentes:

Marco	Aplicabilidad en España	Referencia
NIS2	Entidades esenciales e importantes; ~30.000 org. en España	Dir. UE 2022/2555
DORA	Sector financiero (banca, seguros, fintech, IICI)	Reg. UE 2022/2554
ENS	Sector público y proveedores de AAPP	RD 311/2022
COSO ERM 2017	Universal; referente global de ERM	COSO.org
COSO CGF 2026	Universal; gobierno corporativo ciber	COSO.org
ISO 27001:2022	Universal; certificación de SGSI	ISO/IEC
NIST CSF 2.0	Universal; marco de funciones de ciberseguridad	NIST.gov
NIST IR 8286r1	Universal; integración ERM-ciber	NIST.gov
FAIR	Universal; cuantificación financiera del riesgo ciber	OpenFAIR.org
EU AI Act	Sistemas IA de alto riesgo; desde agosto 2026	Reg. UE 2024/1689

Preguntas Frecuentes

P: ¿Cuánto tiempo lleva responder la encuesta?

R: Aproximadamente 45–60 minutos para un encuestado con acceso a datos de la organización.

P: ¿Un solo encuestado puede responder toda la encuesta?

R: Para obtener la imagen más precisa, se recomienda que respondan:

- Bloque 0, I, II, VII, VIII: CISO / CRO / CEO
- Bloque III, IV, VI: CISO / Equipo técnico de ciberseguridad
- Bloque V: Responsable de Compliance / Auditoría Interna
- Bloque X: Cualquier perfil

P: ¿Qué ocurre si no tenemos todos los datos que se piden?

R: En ese caso, las instrucciones de la encuesta indican explícitamente que se proporcione la mejor estimación disponible. La ausencia de datos precisos es en sí misma un hallazgo diagnóstico relevante.

P: ¿Se pueden comparar los resultados con otras organizaciones del sector?

R: Sí, esa es una de las funcionalidades clave del kit. El Documento (e) incluye un módulo de comparativa sectorial y la Guía Metodológica (Documento b) describe cómo construir benchmarks con grupos de organizaciones participantes.

P: ¿El kit cumple con el RGPD?

R: Sí, siempre que se implementen las instrucciones del Documento (b), §8 (Consideraciones Éticas). Se requiere consentimiento informado, política de privacidad y base legal para el tratamiento de datos.

P: ¿Con qué frecuencia se recomienda repetir el diagnóstico?

R: Anualmente, o ante cambios relevantes en el entorno de amenazas, cambios regulatorios significativos o tras incidentes de ciberseguridad materiales.

Contribuciones y Actualizaciones

Este kit es un instrumento vivo. Las actualizaciones están previstas para:

- v2025.2 (octubre 2025): Incorporación de métricas específicas de AI Security (post-EU AI Act)
- v2026.1 (abril 2026): Actualización de benchmarks con datos ENISA NIS Investments 2025
- v2026.2 (octubre 2026): Incorporación de indicadores PQC conforme al plan de migración CCN

Para notificar errores, proponer mejoras o compartir resultados de aplicación del kit:

- **Repositorio:** [URL del repositorio]
- **Contacto:** [email del equipo de investigación]

Licencia de Uso

Este kit se distribuye bajo licencia **Creative Commons Attribution-NonCommercial-ShareAlike 4.0 International (CC BY-NC-SA 4.0)**.

Puede ser utilizado, adaptado y redistribuido para fines no comerciales, siempre que se cite la fuente original y las obras derivadas se distribuyan bajo la misma licencia.

Citación recomendada:

[Autores/Institución] (2026). *Kit COSO-Ciber v2025.1: Encuesta Integral sobre Indicadores y Métricas de Ciberseguridad en el Marco COSO*. [Institución / DOI si disponible].

Créditos y Agradecimientos

Este kit fue desarrollado con base en las siguientes fuentes primarias:

- COSO (2017). Enterprise Risk Management — Integrating with Strategy and Performance.
- COSO / Deloitte (2020). Managing Cyber Risk in a Digital Age.
- COSO / PwC (2026). Corporate Governance: Guiding Principles for Board Oversight.
- ENISA (2025). NIS Investments 2025.
- INCIBE (2026). Balance de Ciberseguridad 2025.
- CCN-CERT (2025). Ciberamenazas y Tendencias — Edición 2025.
- NIST (2025). IR 8286r1 — Integrating Cybersecurity and Enterprise Risk Management.
- FAIR Institute (2025). State of Cyber Risk Management Report.
- IBM Security (2025). Cost of a Data Breach Report 2025.
- ISO/IEC 27004:2016. Information security management — Monitoring, measurement, analysis and evaluation.
- Deloitte (2025). Global Future of Cyber Survey.
- ISMS Forum España (2025). Informe anual de ciberseguridad en España.

Versión: 2025.1 | Fecha: Abril 2026 | Clasificación: Uso libre (CC) ||
"Medir para mejorar. Reportar para gobernar. Anticipar para sobrevivir."